Title: **Access Control Leading to Unauthorized Admin Panel Access in source code**

Access control enforces policy such that users cannot act outside of their intended permissions. Failures typically lead to unauthorized information disclosure, modification or destruction of all data, or performing a business function outside the user's limits.

Reproduction Steps:

1.visit : https://0a9c00a40411dc6e801471560079004a.web-security-academy.net/

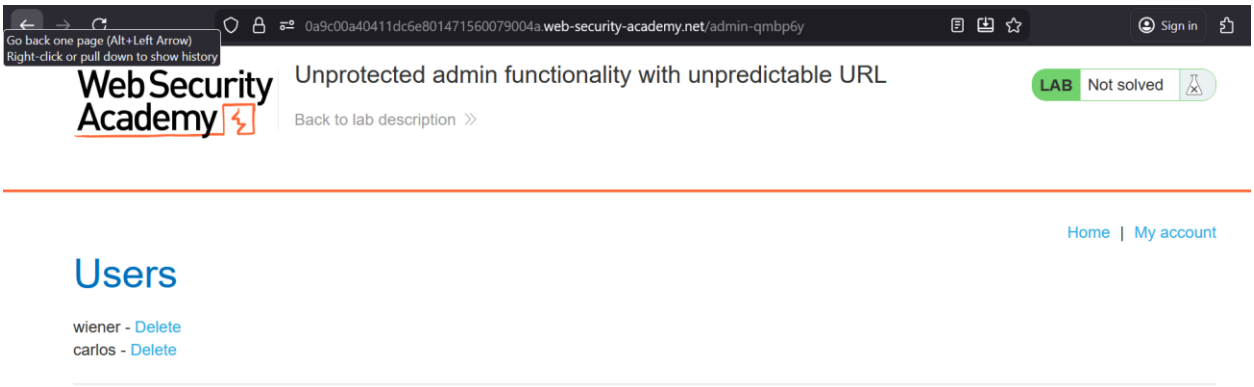
2.open the source code page and search for the (admin)

3.found this block of code

```
                                <script>
var isAdmin = false;
if (isAdmin) {
   var topLinksTag = document.getElementsByClassName("top-links")[0];
   var adminPanelTag = document.createElement('a');
   adminPanelTag.setAttribute('href', '/admin-qmbp6y');
   adminPanelTag.innerText = 'Admin panel';
   topLinksTag.append(adminPanelTag);
   var pTag = document.createElement('p');
   pTag.innerText = '|';
   topLinksTag.appendChild(pTag);
}
</script>
```

4.we will found the name of the admin panel in the code(admin-qmbp6y)

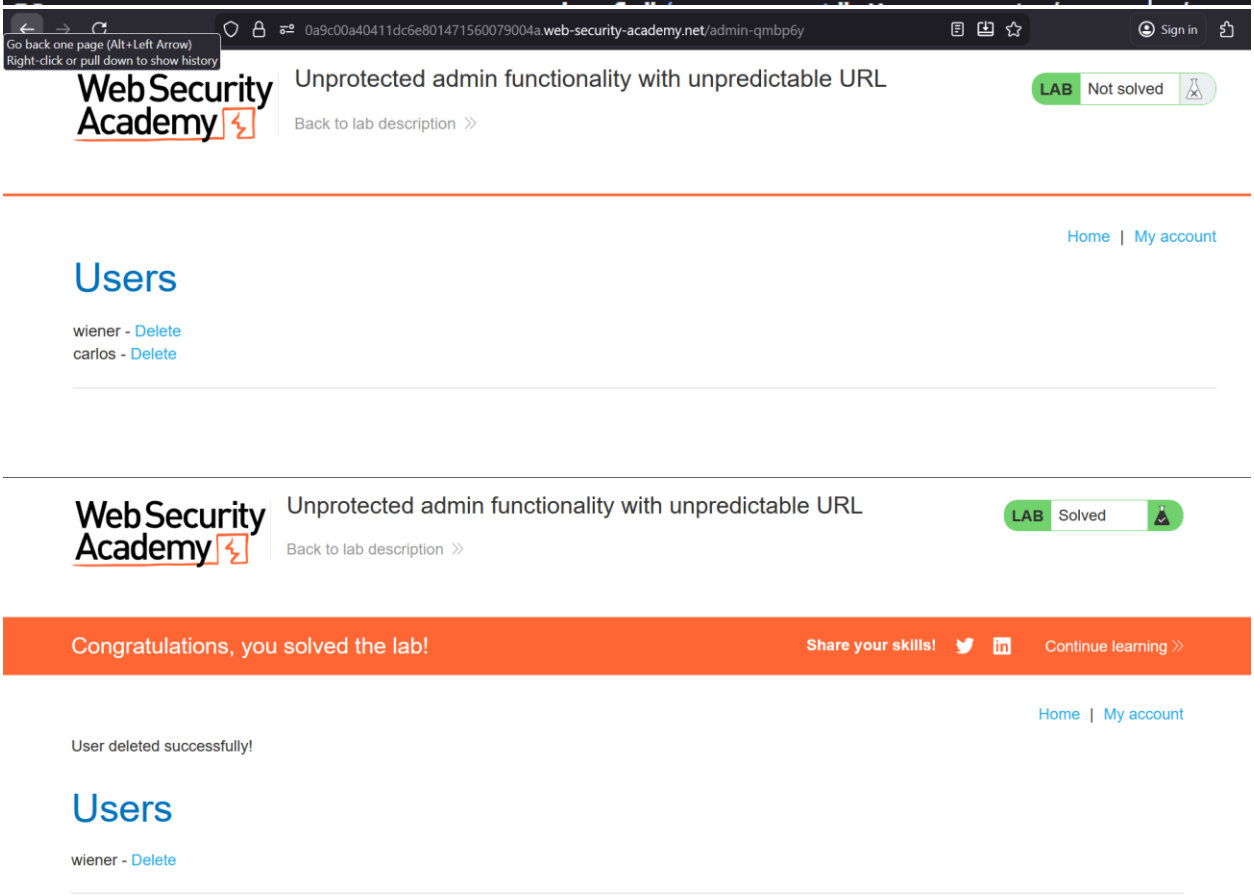
6.put it in the origin URL and you will login into the admin panel page



7. **From the admin panel, the attacker can delete the user "carlos".**

Proof of Concept (PoC):

```
<script>
var isAdmin = false;
if (isAdmin) {
   var topLinksTag = document.getElementsByClassName("top-links")[0];
   var adminPanelTag = document.createElement('a');
   adminPanelTag.setAttribute('href', '/admin-qmbp6y');
   adminPanelTag.innerText = 'Admin panel';
   topLinksTag.append(adminPanelTag);
   var pTag = document.createElement('p');
   pTag.innerText = '|';
   topLinksTag.appendChild(pTag);
}
</script>
```

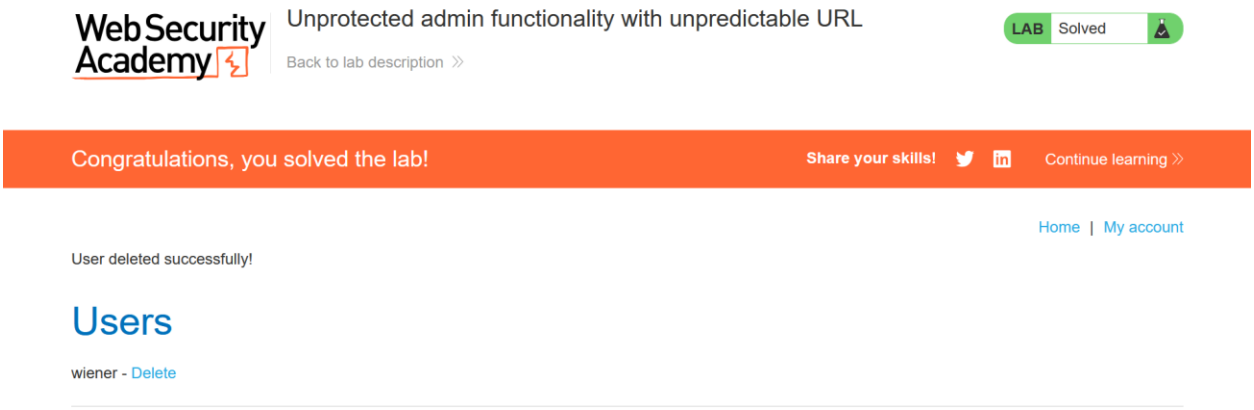


Impact statement:

This vulnerability allows an unauthenticated attacker to access the admin panel.

An attacker can perform administrative actions such as deleting users, modifying data, or disrupting the application functionality.

If exploited in a real-world system, this could lead to privilege escalation, data loss, and full compromise of administrative functionality.



Mitigation :

1.Deny by Default: Assume all access is forbidden and explicitly grant access only to those authorized, enforced on the server-side.

2.Least Privilege: Grant every user the minimum level of permissions they absolutely need to perform their function.

3.Don't Trust the Client: All access control decisions must be made and enforced on the server, not by hiding buttons in the UI.

4.Verify Ownership (IDOR): Ensure every database query verifies that the record belongs to the authenticated user (e.g., WHERE user_id = ?).

5.Log and Monitor: Log every failed access attempt and monitor for unusual patterns to detect